

Botium Toys Security Audit Checklist

This audit was done by Said Al Harthy.

Activity overview

I conducted a comprehensive internal security audit for Botium Toys, a simulated small U.S. business specializing in toys. The audit aimed to assess their current security posture, identify vulnerabilities, and ensure compliance with relevant industry standards and regulations. This project allowed me to apply foundational cybersecurity concepts, including control assessment, risk identification, and compliance evaluation.

Scenario: Botium Toys Background

Botium Toys is a small U.S. business with both physical and online retail operations. Their IT Manager initiated this internal security audit due to growing concerns about maintaining compliance and ensuring robust business operations as the company expands. The goal was to establish a clear security plan and mitigate potential risks by adopting the NIST Cybersecurity Framework.

Scope and Goals of the Audit

- **Scope:** The audit encompassed the **entire security program at Botium Toys**. This included assessing all company assets, internal processes, and procedures related to the implementation of security controls and compliance best practices.
- **Goals:**
 - To assess existing assets.
 - To complete a controls and compliance checklist.
 - To determine which security controls and compliance best practices needed to be implemented to significantly improve Botium Toys' overall security posture.

Current Assets

The audit focused on assets managed by Botium Toys' IT Department, which included:

- **On-premises equipment:** Devices used for in-office business needs.
- **Employee equipment:** End-user devices such as desktops, laptops, smartphones, remote workstations, headsets, cables, keyboards, mice, docking stations, and surveillance cameras.
- **Storefront products:** Inventory available for retail sale (on-site and online), stored in the company's adjoining warehouse.
- **Management of systems, software, and services:** Including accounting, telecommunication, database, security, e-commerce, and inventory management systems.
- **Internet access and internal network.**
- **Data retention and storage.**
- **Legacy system maintenance:** End-of-life systems that require manual human monitoring and intervention.

Risk assessment

Risk description

Currently, there is inadequate management of assets. Additionally, Botium Toys does not have all of the proper controls in place and may not be fully compliant with U.S. and international regulations and standards.

Control best practices

The first of the five functions of the NIST CSF is Identify. Botium Toys will need to dedicate resources to identify assets so they can appropriately manage them. Additionally, they will need to classify existing assets and determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1 to 10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to compliance best practices.

Additional comments

The potential impact from the loss of an asset is rated as medium, because the IT department does not know which assets would be at risk. The risk to assets or fines from governing bodies is high because Botium Toys does not have all of the necessary controls in place and is not fully adhering to best practices related to compliance regulations that keep critical data private/secure. Review the following bullet points for specific details:

- Currently, all Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
- Encryption is not currently used to ensure confidentiality of customers' credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
- Access controls pertaining to least privilege and separation of duties have not been implemented.
- The IT department has ensured availability and integrated controls to ensure data integrity.
- The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
- Antivirus software is installed and monitored regularly by the IT department.
- The IT department has not installed an intrusion detection system (IDS).
- There are no disaster recovery plans currently in place, and the company does not have backups of critical data.
- The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach. Additionally, privacy policies, procedures, and processes have been developed and are enforced among IT department members/other employees, to properly document and maintain data.
- Although a password policy exists, its requirements are nominal and not in line with current minimum password complexity requirements (e.g., at least eight characters, a combination of letters and at least one number; special characters).
- There is no centralized password management system that enforces the password policy's minimum requirements, which sometimes affects productivity when employees/vendors submit a ticket to the IT department to recover or reset a password.
- While legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear.
- The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks, up-to-date closed-circuit television (CCTV) surveillance, as well as functioning fire detection and prevention systems.

Controls Assessment Checklist

Control	In Place?	Explanation
Least Privilege	No	All employees can access sensitive internal data. No access restrictions implemented.
Disaster Recovery Plans	No	No plans or backups exist for data recovery after incidents.
Password Policies	No	Password policy is outdated and does not meet complexity standards.
Separation of Duties	No	Roles and duties are not separated, increasing risk of abuse.
Firewall	Yes	A firewall is in place with defined rules to block unauthorized traffic.
Intrusion Detection System (IDS)	No	No IDS has been installed to detect anomalous activity.
Backups	No	Critical data is not backed up, risking loss during incidents.
Antivirus Software	Yes	Antivirus is installed and regularly monitored.
Manual Legacy System Monitoring	No	Legacy systems are monitored manually without a fixed schedule for these tasks.
Encryption	No	No encryption used for sensitive customer or payment data.
Password Management System	No	No centralized system; password resets handled manually.
Locks (Physical Security)	Yes	Locks in place for office, storefront, and warehouse.
CCTV Surveillance	Yes	Surveillance system is operational and up to date.
Fire Detection/Prevention	Yes	Fire alarms and sprinklers are functional.

GDPR Compliance Checklist

GDPR Best Practice	In Place?	Explanation
E.U. customers' data is kept private/secured.	No	As per risk assessment report data is not kept private/secured
Notify E.U. customers within 72 hours of breach.	Yes	Company has breach notification plan in line with GDPR.
Data is properly classified and inventoried.	No	Assets not classified so risk remains high.
Enforce privacy policies and procedures.	No	They do not have all of the necessary controls in place

System and Organization Controls (SOC) Checklist

SOC Best Practice	In Place?	Explanation
User access policies are established.	No	No role-based access or least privilege policy implemented.
Sensitive data (PII/SPII) is private.	No	No encryption or restriction on sensitive data access, PII/SPII is not confidential
Data integrity ensured.	No	Controls in place to ensure data consistency and integrity.
Data available to authorized users.	No	Data is available to almost all internal employees

Recommendations:

Based on my audit of Botium Toys, it's pretty clear we've got some significant security work ahead of us. The current setup leaves us quite vulnerable. To protect Botium Toys and ensure we're compliant with regulations like PCI DSS and GDPR, here are my key recommendations for the IT manager:

- **Tighten Up User Access (Least Privilege & Separation of Duties):** Right now, pretty much everyone has access to everything, including sensitive customer data. We urgently need to implement "least privilege" (giving people only the access they need for their job) and "separation of duties" (splitting critical tasks among different people). This is crucial to prevent internal misuse or accidental breaches, and it's a big step towards PCI DSS and SOC compliance.
- **Encrypt Everything Sensitive (Especially Credit Cards!):** Our customer credit card data isn't encrypted when it's stored or processed, which is a major red flag for

PCI DSS. We need to get encryption in place for all payment information to keep it confidential and secure this could eventually leak SPII.

- **Get Serious About Backups and Disaster Recovery:** We currently don't have any formal disaster recovery plans or proper backups of our critical data. This is super risky! If something goes wrong (like a system failure or a ransomware attack), we could lose everything. We need to create and regularly test plans for how we'd recover our systems and data, and set up reliable backup solutions.
- **Fix Our Password Problem:** Our current password policy is too weak, and we don't have a centralized system to manage them. This makes us an easy target for attacks and causes productivity issues. We need to implement a strong password policy (think complex requirements, not just 8 characters!) and get a proper password management system in place.
- **Install an Intrusion Detection System (IDS):** We currently don't have an IDS, which means we're missing a key tool for spotting suspicious activity on our network. Getting an IDS would greatly improve our ability to detect potential threats early.
- **Prioritize PCI DSS & GDPR Compliance:** Many of the issues I found directly impact our compliance with these regulations. We need to focus on closing these gaps quickly to avoid significant fines and maintain trust with our customers, especially those in the E.U.